MW REALTY CRM · TESTER HANDBOOK · MODULE 22

Security

Two-factor authentication, new-device email check, recovery codes, recognised devices and the agent / agency sign-in steps

Where: CRM avatar (account) menu › **Security** (`/crm/security`). Set-up screen: `/crm/security/two-factor` . Sign-in: `/login` › tab **Agent / Agency** (`/agent-login` and `/agency-login` open the same page). **Who:** Agency and Agent accounts. Not for Super Admin. **Locks:** none. Security is **available while KYC is pending** and on every plan.

1. What this module does

Security protects an agent or agency account at sign-in. The account owner can turn on **two-factor authentication (2FA)** with an authenticator app (Authy, Google Authenticator, Microsoft Authenticator). With 2FA on, every sign-in needs the password **and** a 6-digit code from the app. A sign-in from a new browser or device also needs a code sent by email. An agency can make 2FA **mandatory** for all agents in its company.

There is **no password change** on this screen. There is no list of signed-in sessions to end; the screen lists **Recognised devices** (browsers that passed the email check).

Security screen

Heading “Security”. Cards: **2-Factor Authentication (My Company)** (agency only, a switch), **2-Factor Authentication** (status pill Enabled / Disabled, methods, recovery codes, **Disable 2FA**), **Recognised devices**. Side panel **How it works** and tip **Changing your phone?**

Two-Factor Authentication set-up

Three steps: **Install an authenticator app**, **Scan the QR code**, **Enter the 6-digit code** (six boxes). QR code with a text key under “Can't scan? Enter this key in the app instead:”. Button **Verify & Enable**.

Recovery codes screen

“Save your recovery codes”. Shows 8 codes once, with **Copy**, **Download** and **I've saved them, continue**.

Sign-in steps (website)

After the password: “Verify it's you” (email code, new device only) and “Two-factor authentication” (app code or a recovery code).

2. How it works (business rules)

Sign-in flow for Agent / Agency

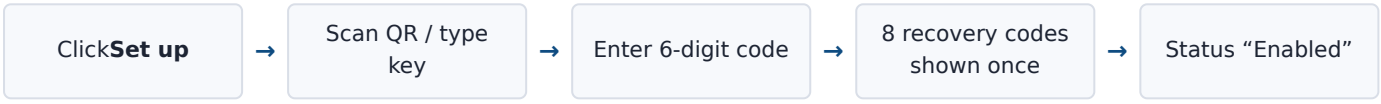
Email + password → Email code (only new device, only if 2FA on) → App code or recovery code (only if 2FA on) → CRM Dashboard

- **2FA off:** the password alone signs in. No email code is asked, even on a new device.
- **2FA on, known device:** password, then the app code. The email step is skipped.
- **2FA on, new device:** password, then “Verify it's you” with a code emailed to the account (email shown masked, e.g. `sa••••@example.com`), then the app code. After success the browser is remembered.
- **Email code:** 6 digits, valid for **10 minutes**. Link **Resend code** sends a new one (“A new code has been sent.”). The whole sign-in attempt expires after **15 minutes**: “Your sign-in session has expired. Please

enter your email and password again.”

- **Wrong codes:** email step “Invalid or expired code.”; app step “That code is not valid. Check your authenticator app and try again.” After **5 wrong codes** in one sign-in attempt (both steps counted together): “Too many incorrect codes. Please sign in again.” and the form returns to email + password.
- **App code rules:** exactly 6 digits; codes change every 30 seconds; the code just before and just after the current one are also accepted (small clock difference). The same code cannot be used twice: after a code is accepted, that code and older ones are refused.
- **Recovery code at sign-in:** on the “Two-factor authentication” step the tester can type a recovery code instead of the app code (“Lost your phone? Enter one of your recovery codes instead.”). Each recovery code works once. Dash and upper/lower case do not matter.
- **Wrong password / unknown email:** “Invalid credentials.” **Disabled account:** “Your account has been disabled. Contact the site administrator.”
- **KYC pending or rejected** accounts can sign in. They can use My Profile and Security; other modules stay locked until approval.

Setting up 2FA



- The six code boxes move to the next box by themselves, accept paste of the full code, and send the code automatically when all 6 digits are filled.
- Success message: “Two-factor authentication is now enabled.” A wrong code shows “That code is not valid. Make sure you scanned the latest QR code and that your phone's time is correct.” and clears the boxes.
- A QR code is valid for **30 minutes**. After that: “Your set-up expired — start again to get a new QR code.” Reloading the page makes a new QR code; an older QR code then no longer matches.
- When 2FA is on, the “New device email check” method shows **On** and the counter shows “8 of 8 recovery codes left”.
- Opening `/crm/security/two-factor` when 2FA is already on sends the user back to Security.

New account (after sign-up)

- After the sign-up email code is verified, the new account lands on the set-up screen with the label “Last step · Secure your account”.
- The user must either set up 2FA or click **Skip for now, I'll do this later from Security**. Until then, every other CRM page sends them back to the set-up screen.
- After **I've saved them, continue** (or Skip) the user goes to the Dashboard.

Mandatory 2FA for a company (agency only)

- The agency sees the card **2-Factor Authentication (My Company)** with a switch.
- The agency must have 2FA on itself first. If it turns the switch on without 2FA, it is sent to the set-up screen with: “Set up 2FA on your own account first. Mandatory 2FA for your company turns on automatically when you finish.” After a correct code: “Two-factor authentication is enabled, and is now mandatory for all agents in your company.”
- With 2FA already on, switching on shows: “Two-factor authentication is now mandatory for all agents in your company. They'll be asked to set it up on their next visit.” Switching off: “Two-factor authentication is no longer mandatory for your company.”
- Agents who belong to that agency and have no 2FA are held on the set-up screen on their next page load, with “Your company requires two-factor authentication. Set it up to continue using the portal.” They have **no Skip and no Cancel**.

- While the rule is on, the agent sees “Your agency has made 2FA mandatory, so it can't be turned off.” and no **Disable 2FA** button. The agency itself also has no Disable button while its switch is on.
- Independent agents (not in an agency) are never forced.

Change phone, new recovery codes, disable (password needed)

- Each of these opens a pop-up that asks for **Your password**. Wrong password: “The password is incorrect.” under the field.
- **Reconfigure** (pop-up “Move to a new phone”, button **Continue**): opens the set-up screen titled “Move 2FA to a new phone”, button **Verify new phone**. The old app keeps working until the new code is verified. Success: “Your new authenticator app is set up. The old one no longer works.” A new set of 8 recovery codes is shown; the old codes stop working.
- **Generate new codes** (pop-up “Generate new recovery codes”, button **Generate**): message “New recovery codes generated — the old ones no longer work.” The new 8 codes are shown once.
- **Disable 2FA** (pop-up “Disable 2FA”): message “Two-factor authentication has been turned off.” Status pill changes to Disabled, recovery codes are deleted, the app code is no longer asked at sign-in.

Recognised devices

- A browser is remembered after a successful sign-in (and after the sign-up email check). Each row shows a laptop or phone icon, the browser description, IP address and “last used” time. Empty: “No devices yet.”
- A device not used for **180 days** is no longer trusted.
- **Forget other devices** appears only when more than one device is listed. Message: “All other devices will need email verification on their next sign-in.” The current browser stays in the list.

Automatic behaviour and other effects

- **Email:** the new-device code email is sent to the account email with the browser/OS and IP. If sending fails: “Could not send the verification email right now — please try again in a moment.”
- **Session ends automatically** when Super Admin disables the account or sets a new password for it: the next CRM action signs the user out (“Your session has expired. Please sign in again.”) and opens the sign-in page.
- **Super Admin help for a locked-out user:** Admin › portal account detail › **Reset 2FA** (only shown when the account has 2FA on). The user can then sign in with just the password and set 2FA up again. If their agency still makes 2FA mandatory, they are held on the set-up screen again.
- **Rate limits** (see section 7) apply to sign-in and to every code step.

3. Who can do what

Action	Super Admin	Agency	Agent (independent)	Agent (in agency)
See **Security** in the avatar menu	**No (menu shows “Back to Admin”)**	**Yes**	**Yes**	**Yes**
Set up / reconfigure 2FA, new recovery codes	**No (CMS has its own)**	**Yes**	**Yes**	**Yes**
Disable 2FA	**No**	**Only while company switch is off**	**Yes**	**Only if agency does not require it**

Action	Super Admin	Agency	Agent (independent)	Agent (in agency)
Skip 2FA after sign-up	—	Yes	Yes	Not if agency requires it
Card “2-Factor Authentication (My Company)”	No	Yes	No	No
Forget other devices	No	Yes	Yes	Yes
Reset another account's 2FA / password	Yes, in Admin	No	No	No
KYC pending: open Security	—	Yes	Yes	Yes
Free plan / any plan	—	No plan lock	No plan lock	No plan lock

If a Super Admin opens `/crm/security` directly, the page shows an error (for example “Two-factor settings belong to agent and company accounts.”) instead of the settings. This is expected.

4. Fields and validation

Field	Required	Rules / limits
Sign-in Email	Yes	Valid email format.
Sign-in Password	Yes	Must match the account.
Verification code (email step)	Yes	The 6-digit code from the newest email; expires after 10 minutes; max 20 characters in the box.
Authentication code (sign-in)	Yes	6-digit app code, or one unused recovery code (format `XXXXX-XXXXX`, dash optional, any case).
6-digit code (set-up)	Yes	Exactly 6 digits; letters are ignored by the boxes. Only app codes, not recovery codes.
Your password (pop-up)	Yes	Needed for Reconfigure, Generate new codes, Disable 2FA. Wrong: “The password is incorrect.”

5. Test scenarios

Priority: **High** core flow / data loss / access · **Medium** · **Low** cosmetic. Use a phone or desktop authenticator app on a test account. Use a second browser (or a private window) as the "new device".

	Scenario	Steps	Expected result
SEC-01	**Open Security** High	1. Sign in as an Agent with 2FA off. 2. Avatar menu › **Security**.	URL `/crm/security`. Pill "Disabled". Authenticator App row shows **Set up**. New device email check shows "Off". No "My Company" card for an agent.
SEC-02	**Sign in, 2FA off** High	1. Open `/login`, tab **Agent / Agency**. 2. Enter correct email and password, **Sign In**.	Goes straight to the CRM Dashboard. No email code and no app code asked, also in a new browser.
SEC-03	**Wrong password / unknown email** High	1. Enter a wrong password, **Sign In**. 2. Repeat with an email that does not exist.	"Invalid credentials." both times. No hint whether the email exists.
SEC-04	**Disabled account** High	1. Super Admin disables a test account in Admin. 2. Sign in with that account.	"Your account has been disabled. Contact the site administrator." No CRM access.
SEC-05	**Set up 2FA** High	1. Security › **Set up**. 2. Scan the QR code with the app. 3. Type the 6 digits.	Code is sent by itself when the 6th digit is typed. "Two-factor authentication is now enabled." "Save your recovery codes" screen with 8 codes like `A1B2C-D3E4F`.
SEC-06	**Set-up with the text key** Medium	1. Start set-up. 2. Click the copy icon next to the key; add it to the app by hand. 3. Enter the code.	Copy icon changes to a tick for a moment. The key is shown in groups of 4. The code is accepted; "MW Realty" appears in the app.
SEC-07	**Wrong set-up code** High	1. On set-up, enter 6 wrong digits.	"That code is not valid. Make sure you scanned the latest QR code and that your phone's time is correct." Boxes are cleared, focus in the first box. 2FA stays off.
SEC-08	**Code boxes behaviour** Low	1. Paste a 6-digit code into the first box. 2. Type letters; use Backspace and arrow keys.	Paste fills all boxes and submits. Letters are not accepted. Backspace in an empty box goes to the previous one; arrows move between boxes.
SEC-09	**Old QR code after reload** Medium	1. Start set-up and scan the QR. 2. Reload the page (a new QR appears) and enter the code from the first scan.	Code is refused (not valid). Scanning the new QR and entering its code works.
SEC-10	**Recovery codes screen** Medium	1. After SEC-05, click **Copy**, then **Download**. 2. Click **I've saved them, continue**.	Copy shows "Copied". File `mw-realty-recovery-codes.txt` downloads with the account email and 8 codes. Continue goes to Security; pill "Enabled", chip "Configured", "8 of 8 recovery codes left", email check "On".
SEC-11	**Sign in, 2FA on, known browser** High	1. Sign out. Sign in again in the same browser.	After the password: "Two-factor authentication" step only (no email step). Correct app code opens the Dashboard.

	Scenario	Steps	Expected result
SEC-12	**Sign in, 2FA on, new device** High	1. Open a private window / other browser. 2. Sign in with password. 3. Enter the emailed code, then the app code.	“Verify it's you” with masked email. Email arrives with device and IP. Then the app-code step, then Dashboard. Security › Recognised devices now lists this browser.
SEC-13	**Wrong email code / resend** High	1. On “Verify it's you”, enter a wrong code. 2. Click **Resend code**; enter the new code.	“Invalid or expired code.” Resend shows “A new code has been sent.” The newest code works; the earlier code no longer works.
SEC-14	**Expired email code** Medium	1. Get an email code, wait more than 10 minutes, enter it.	“Invalid or expired code.” After 15 minutes from the password step: “Your sign-in session has expired. Please enter your email and password again.” and the form goes back to email + password.
SEC-15	**Wrong app code at sign-in** High	1. On “Two-factor authentication”, enter 000000.	“That code is not valid. Check your authenticator app and try again.” The field is cleared.
SEC-16	**Five wrong codes** High	1. Enter a wrong code 5 times in one sign-in attempt.	On the 5th: “Too many incorrect codes. Please sign in again.” Form returns to email + password (password field empty).
SEC-17	**Same app code twice** Medium	1. Sign in with an app code. 2. Sign out and sign in again at once using the same code (before it changes).	Second use is refused (“That code is not valid…”). The next new code works.
SEC-18	**Sign in with recovery code** High	1. On the app-code step, enter a recovery code (try lower case, without the dash). 2. Open Security. 3. Sign in again with the same recovery code.	First use signs in. Security shows “7 of 8 recovery codes left”. Second use of the same code is refused.
SEC-19	**Back to sign in** Low	1. On a code step click **Back to sign in**.	Email + password form shown again; password field is empty.
SEC-20	**Generate new recovery codes** High	1. Security › **Generate new codes**. 2. Enter the password, **Generate**. 3. Try an old code at sign-in.	“New recovery codes generated — the old ones no longer work.” 8 new codes shown once. Counter back to 8 of 8. Old code refused at sign-in.
SEC-21	**Wrong password in pop-up** High	1. Click **Disable 2FA** (or Reconfigure / Generate new codes). 2. Enter a wrong password.	“The password is incorrect.” under the field; pop-up stays open; nothing changes. **Cancel** closes it.

	Scenario	Steps	Expected result
SEC-22	**Reconfigure (new phone)** High	1. Security › **Reconfigure**, password, **Continue**. 2. Before verifying, sign in on another browser with the old app code. 3. Scan the new QR on a second app, **Verify new phone**.	Title “Move 2FA to a new phone”. Old app still works in step 2. After verify: “Your new authenticator app is set up. The old one no longer works.” New recovery codes shown; old app codes and old recovery codes refused.
SEC-23	**Cancel reconfigure** Medium	1. Start Reconfigure, then click **Cancel**.	Back on Security. 2FA still on with the old app; old recovery codes still valid.
SEC-24	**Disable 2FA** High	1. Security › **Disable 2FA**, password, **Disable 2FA**. 2. Sign out and sign in on a new browser.	“Two-factor authentication has been turned off.” Pill “Disabled”, Set up button back, email check “Off”. Sign-in needs only the password.
SEC-25	**Recognised devices list** Medium	1. With 2FA on, sign in from desktop and from a phone browser. 2. Open Security.	Both listed (laptop and phone icons), with IP and time, newest first. Long names are cut with “…”; full text on mouse-over.
SEC-26	**Forget other devices** High	1. With 2 or more devices listed, click **Forget other devices**. 2. Sign in on one of the other devices.	“All other devices will need email verification on their next sign-in.” List shows only the current browser; button disappears. The other device gets the “Verify it's you” step again.
SEC-27	**Sign-up onboarding: skip** High	1. Register a new test agent; verify the sign-up email code. 2. On the set-up screen try to open `/crm/dashboard`. 3. Click **Skip for now, I'll do this later from Security**.	Lands on set-up with “Last step · Secure your account”. Step 2 sends the user back to set-up. After Skip: Dashboard opens; later visits are not redirected.
SEC-28	**Sign-up onboarding: set up** Medium	1. New account: complete set-up on the onboarding screen. 2. Click **I've saved them, continue**.	Goes to the Dashboard (not Security).
SEC-29	**Agency enables mandatory 2FA without own 2FA** High	1. Sign in as Agency with 2FA off. 2. Turn on the “My Company” switch. 3. Finish set-up.	Switch goes back off; set-up opens with “Set up 2FA on your own account first…”. After the code: “Two-factor authentication is enabled, and is now mandatory for all agents in your company.” Back on Security the switch is on.
SEC-30	**Agency switch on / off** High	1. Agency with 2FA on: turn switch on. 2. Turn it off.	On: “Two-factor authentication is now mandatory for all agents in your company. They'll be asked to set it up on their next visit.” Disable 2FA button hidden. Off: “Two-factor authentication is no longer mandatory for your company.” Disable 2FA button back.

	Scenario	Steps	Expected result
SEC-31	**Agent forced by agency** High	1. Agency turns the switch on. 2. An agent of that agency (2FA off) opens any CRM page.	Agent is sent to the set-up screen: “Your company requires two-factor authentication. Set it up to continue using the portal.” No Skip / Cancel link. Other CRM pages keep redirecting until set-up is done.
SEC-32	**Forced agent cannot disable** High	1. Agent of an enforcing agency, 2FA on, opens Security.	Notice “Your agency has made 2FA mandatory, so it can't be turned off.” No **Disable 2FA** button. Reconfigure and Generate new codes still work.
SEC-33	**Independent agent not affected** Medium	1. Agency enforces 2FA. 2. Sign in as an independent agent (no agency) with 2FA off.	No redirect to set-up; CRM works normally.
SEC-34	**KYC pending account** High	1. Sign in as an account whose KYC is not approved. 2. Open Security; set up and disable 2FA.	Sign-in works. Security has no lock and all actions work. Plans, Leads etc. still show “Unlocks after KYC approval”.
SEC-35	**Super Admin view** Medium	1. Open CRM from `/admin` as Super Admin. 2. Open the avatar menu; then open `/crm/security` directly.	Menu has “Back to Admin”, no Security. Direct URL shows an error text with **Try again**, no settings.
SEC-36	**Super Admin resets a user's 2FA** High	1. Admin › portal account detail of a test agent with 2FA on › **Reset 2FA**, confirm. 2. Agent signs in.	“Two-factor authentication has been reset for this account.” Agent signs in with password only; Security shows Disabled. (If the agency enforces 2FA, the agent is sent to set-up.)
SEC-37	**Session ends after admin change** High	1. Agent is signed in to the CRM. 2. Super Admin sets a new password for that account (or disables it). 3. Agent clicks any menu item.	Agent is signed out and taken to the sign-in page. Old password no longer works; new one does.
SEC-38	**Sign-in rate limit** Medium	1. Enter a wrong password for the same email 6 times within one minute.	From the 6th attempt the sign-in is refused with a “too many attempts” error, even with the right password. Works again after about one minute.
SEC-39	**Set-up time-out** Low	1. Start set-up, wait more than 30 minutes without reloading, enter a correct code.	“Your set-up expired — start again to get a new QR code.” Reloading gives a new QR code that works.
SEC-40	**Mobile width** Low	1. Open Security and set-up at phone width (about 375 px).	Cards stack; side panel below the main cards; QR code and code boxes fully visible; no sideways scrolling; pop-up fits the screen.

6. Expected results checklist

- [ ] Without 2FA, the password alone signs in on any device.

- [ ] With 2FA, every sign-in asks the app code; a new browser also asks the emailed code first.
- [ ] Wrong codes show the exact messages; 5 wrong codes restart the sign-in.
- [ ] App codes cannot be reused; recovery codes work once each and the counter goes down.
- [ ] 8 recovery codes are shown once after set-up, reconfigure and Generate new codes; old codes stop working.
- [ ] Reconfigure, Generate new codes and Disable 2FA all require the correct password.
- [ ] Agency “My Company” switch forces agents of that agency to set up 2FA, with no skip and no disable.
- [ ] Forget other devices keeps only the current browser and the others get the email step again.
- [ ] New accounts must set up or skip 2FA before using the CRM.
- [ ] Security works during KYC pending and on every plan; Super Admin does not use this screen.
- [ ] Account disable or admin password reset ends the user's open session.

7. Known behaviour (not bugs)

By design:

- The new-device email check only happens when 2FA is on. With 2FA off, a new device signs in with the password only.
- The agency's own Disable 2FA button is hidden while its “My Company” switch is on (it must switch that off first). No notice is shown to the agency about this.
- Reconfigure also replaces the recovery codes.
- Recovery codes can be used at sign-in, not in the set-up code boxes.
- Forget other devices from the CRM mobile app forgets every device, including the phone itself.
- There is no password change and no “sign out other sessions” on this screen. “Forgot your password?” on the sign-in page belongs to website user accounts; an agent / agency password can be set by Super Admin in Admin.
- The CRM mobile app uses the same sign-in rules and messages.

Test-data cautions:

- Use only dedicated test accounts and a test authenticator entry. Never use a real or shared account; never put passwords, QR codes, keys or recovery codes in bug reports or screenshots.
- Keep the recovery codes of each test account, or ask Super Admin to use **Reset 2FA** if you lock yourself out.
- **Rate limits are shared per network (IP address):** sign-in allows 5 tries per minute per email (30 per minute per IP). All code steps (sign-in codes, Resend, set-up confirm, Generate new codes, Disable 2FA) together allow 8 per minute and **30 per day per IP**. Testers in the same office share these limits; plan the code-heavy scenarios and do not repeat them without need.
- The test environment may be set to accept a fixed email code instead of sending email. Ask the test lead which applies.
- Turning on the agency “My Company” switch affects every agent of that agency. Use a test agency only.

8. Reporting a bug

Include: module (Security), role and account email (test account), agency or independent, KYC status, 2FA on/off, browser/device (new or recognised), steps, expected vs actual, exact message, time, screenshot. Never include passwords, QR codes, secret keys or recovery codes.